02 — Lifecycle Manager: vulnerabilities, threats, and CVEs

Date: 2026-10-25 **Scope:** NVIDIA LCM only. No exploit steps, no PoC payloads. **govulncheck:** exit **0** after the pin bump (was exit 3 / 43 call-graph hits).

1. Supply-chain CVEs (govulncheck)

`make govulncheck` originally failed with **43 call-graph findings**. The OSV dump listed hundreds of catalog records; **findings** were the ones on our call graph.

What we found (and patched)

Area	Old pin	New pin	Vuln IDs (Go)	Notes
Go toolchain	(default 1.26.x)	**go1.26.10**	through GO-2026-6809	stdlib; do not only bump the `go 1.26.0` language line
grpc	v1.79.3 / 1.83.1	**v1.83.2**	GO-2026-6348, GO-2026-6443, GO-2026-6061	1.83.1 still had GO-2026-6443
golang.org/x/net	v0.49.0	**v0.60.0**	HTTP/2 set through GO-2026-6617	HTTP/2 already disabled on webhook/metrics
golang.org/x/text	v0.33.0 / 0.39	**v0.42.0**	GO-2026-5970	0.39 was not enough for x/net 0.60
otel	v1.40.0	**v1.45.0**	GO-2026-6505	
cel-go	older import-only	**v0.30.0**	GO-2026-6094	import-only still required the bump
k8s.io/*	v0.36.0	**unchanged v0.36.0**	—	same minor as lab k3s 1.36.4

`TestPatchedGovulnDependencies` fails the suite if those floors drop.

How we tested the CVE patch

```
export GOTOOLCHAIN=go1.26.10
go test ./pkg/lifecycle/ -count=1 -run TestPatchedGovulnDependencies
make govulncheck          # must exit 0
go test ./pkg/lifecycle/ -count=1
go test -race ./pkg/lifecycle/ -count=1
```

JSON dump after the fix: catalog records still exist in OSV; **0 findings** on this module's call graph.

What we did not do

- Did not bump k8s past v0.36.0.
- Did not import `helm.sh/helm/v3` (v3.21.4 → k8s 0.36.2; v3.22.1 → 0.37.1).
- Did not treat "NVD fetch aborted" as a finding.

2. Design / runtime threats (not CVE IDs)

These are the LCM-specific threats we found by code review, pentest (Info only), and the 2000-user stress run.

T1 — Helm argument / chart URL injection

Threat: annotations like `lifecycle.opi.nvidia.com/helm-args`, `helm-set`, `chart-url` could point Helm at a hostile chart or pass `--` flags.

How patched: `ValidateInstallConfig` / `RejectInstallOverrides` / `ValidateArtifactRef`. Forbidden keys in `config.go`. Desired NVIDIA version must be the **exact pin string** `v26.4.0`. Webhook `ValidateDpuOperatorAdmission` denies the same on CREATE/UPDATE.

Test: `TestValidateDpuOperatorAdmissionRejectsHelmOverride`, `TestValidateInstallConfigRejectsOverrides`.

T2 — Silent adopt of unmanaged live DPF

Threat: LCM takes over `owner=helm` `dpf-operator` and upgrades or uninstalls lab DPF.

How patched: adopt only if adapter already owns **or** `lifecycle.opi.nvidia.com/adopt-existing=true` **and** identity matches the pin. Cleanup of adopted pins defaults to **retain**. `ClusterHelmClient` refuses release name `dpf-operator` for install/upgrade/uninstall.

Test: `TestEnsureInstalledSecretHelmReportsUnmanaged`, `TestClusterHelmClientRefusesLiveDPFName`, `TestHelmUninstallRefusesExternalRelease`.

T3 — Cluster-wide Secret watch

Threat: informer lists/watches all Secrets (tokens, kubeconfigs).

How patched: `Client.Cache.DisableFor corev1.Secret` in `cmd/main.go`. RBAC: secrets get/list/update/patch — **no watch**, no create/delete.

Test: `TestMainDisablesSecretInformer`, `TestManagerRoleListsHelmSecrets`.

T4 — Reconcile write storm / 409 (pointer 1)

Threat: many writers on one `DpuOperatorConfig` (second replica, raised workers, burst patches) → 409 → requeue storm → OOM (pod 128Mi).

How patched: per-name lock in `Reconcile`; `RetryOnConflict` on finalizer and status (re-Get so daemon `Ready` is not overwritten); `MaxConcurrentReconciles=1`; `--leader-elect` default **true**; Deployment already `replicas: 1`.

Test: `TestConcurrentReconcileSameConfigSucceeds` (32-way, 0 errors); stress 2000 same config: OK.

T5 — ClusterHelm TOCTOU (pointer 2)

Threat: concurrent Install of `opi-lcm-probe` Create/Update races.

How patched: per-release lock; retry on 409; AlreadyExists treated as conflict and retried.

Test: `TestConcurrentClusterHelmInstallOneWinner`, `TestConcurrentClusterHelmUpgradeNoConflict`.

T6 — ClaimRelease 409 on live Helm Secret (pointer 3)

Threat: thousands of `adopt-existing` users stamp `sh.helm.release.v1.dpf-operator.v1`.

How patched: dedicated `claimReleaseLocks` (not `defaultReleaseLocks` — that nested lock **deadlocked** `TestEnsureInstalledSecretHelmClaimsMatchingPin` for 6 minutes). `RetryOnConflict`. Skip Update if already adopted. Wrong version (`v26.3.9`) not stamped.

Test: `TestClaimReleaseIsIdempotent` (second claim: 0 extra Updates), `TestConcurrentClaimReleaseSameSecretSucceeds`, `TestConcurrentEnsureInstalledAdoptExisting`.

T7 — Log / values leak

Threat: Helm values or reasons containing tokens land in logs.

How patched: `SanitizeLogValue` / `SanitizeVendorToken`. Tests ban password/token/kubeconfig in log helpers.

T8 — HTTP/2 Rapid Reset on metrics/webhook

Threat: GHSA-qppj-fm5r-hxr3 / GHSA-4374-p667-p6c8.

How patched: HTTP/2 disabled unless `--enable-http2` (default false) in `cmd/main.go`. Metrics default `--metrics-secure=true` with authn.

T9 — Missing admission / API flood

Threat: anyone who can patch `DpuOperatorConfig` can thrash reconcile.

How patched (code): validating webhook handler + manifests (`failurePolicy: Fail` when enabled). APF Limited queue for the adapter SA (`config/apf/`). Webhook **not** turned on in `config/default` yet (needs certs). APF **not** applied to dh2 from this work.

T10 — Fake success when Helm/OLM cannot mutate

Threat: missing Helm storage reported as Ready install.

How patched: detect-only fallthrough; `AssessReadiness` requires operator observation Ready **and** version window **and** install present. Missing Argo/cert-manager → `SkewBlocked`, not success.

T11 — Pentest (Info only, no medium+)

Security review: no medium+ backdoor. Info leftovers:

- Cluster-wide secrets/subscriptions RBAC without `resourceNames`
- Annotation version vs observed Helm can disagree (annotation wins by

design)

- Cleanup list-error skip (retain)
- `ChartRoot` + `ChartVersion` path join if ChartRoot is later set

No exploit text in this report. No keys copied.

3. What is not a software CVE

Item	Why
DPU Rebooting / pending NVCONFIG	Host-agent wants `mlxfwreset` level 3. Lab rule: do not run it. LCM reports `VendorDPUReady=False`.
`dscdevices.dpu.amd.com` NotFound	Required on Pensando, not on this BlueField. Stubs not applied.
Kind e2e docker.sock miss	Environment, then gated by `make docker-preflight`.

4. Commands that prove the security pin

```
export GOTOOLCHAIN=go1.26.10
make govulncheck
go test ./pkg/lifecycle/ -count=1 -run 'TestPatchedGovulnDependencies|TestMainDisablesSecretInformer|TestManagerRol
go test -race ./pkg/lifecycle/ -count=1 -run 'TestConcurrentReconcile|TestConcurrentClusterHelm|TestConcurrentClaim
```

Live ClusterRole (after apply of generated role, live name `opi-nvidia-dpf-adapter-manager-role`): **no wildcards**. Confirm:

```
k3s kubectl get clusterrole opi-nvidia-dpf-adapter-manager-role -o yaml | grep -E '^\s+- \*'
# expect no match
```